# *REPORTE DE PENTESTING.*

4Geeks Academy

Servidor Debian 192.168.1.148

Test de penetración.

21/03/2026

Nelson Vasquez Gurumendi

Linux 6.1.0-44-amd64

# *Contenido.*


1. Resumen.
2. Introducción.
3. Objetivo
4. Alcance.
5. Metodología.
6. Resultados del reconocimiento.
7. Hallazgos de seguridad.
8. Corrección de vulnerabilidades.
9. Conclusión.
10. Anexos.

# 1. Resumen.

Se llevo a cabo un test de penetración sobre un servidor Debian con la finalidad de identificar vulnerabilidades y evaluar así su impacto en la seguridad.

Se identificaron múltiples fallos críticos en la seguridad,  en los cuales se incluye:

- XML-RPC habilitado en WordPress.
- Configuraciones inseguras en archivos de seguridad critica.
- Acceso a FTP sin autenticación.
- Exposición de directorios web.

Estas vulnerabilidades dar permiso a un atacante potencial, abre la puerta a posibles invasiones de tipo:

- Realizar ataques de fuerza bruta.
- Comprometer servicios web.
- Acceso sin credenciales.
- Obtención de información sensible.

# 2. Introducción.

Este informe documenta el análisis realizado a la seguridad de un servidor de Debian aplicando técnicas de pentesting.

# 3. Objetivo.

La finalidad es identificar vulnerabilidades explotables, demostrar su criticidad e impacto y proponer medidas para la adecuada corrección de los mismos.

Estas vulnerabilidades podrían dar permiso a un atacante de:

- Obtener acceso no autorizados.
- Realizar ataques de fuerza bruta.
- Escalada de privilegios.
- Comprometer en gran magnitud los servicios web.

## 4. Alcance.

El sistema evaluado durante este análisis fue:

- Servidor debian.
- IP: 192.168.1.148

Los servicios analizados fueron:

- SSH (22)
- FTP(21)
- HTTP (80)
- WordPress

## 5. Metodología.

Se utilizo una metodología basada en etapas:

1. Reconocimiento
2. Enumeración
3. Identificación de vulnerabilidades
4. Explotación
5. Mitigación
6. Verificación

Y posteriormente se evaluaron las vulnerabilidades mediante la identificación de las debilidades explotables de este servidor.

Se utilizaron herramientas tales como:

| ***Herramienta*** | ***Finalidad*** |
|---|---|
| *Nmap* | Escaneo de puertos y servicios. |
| *Dirb/Gobuster* | Enumeración web. |
| *WPScan* | Análisis de WordPress. |
| *Navegador web* | Validación manual. |
| *Nikto* | Identificación de vulnerabilidades |

## 6. Resultado del reconocimiento.

Durante la fase de reconocimiento y enumeración se identifico una superficie de ataque amplia, esta es una afirmación compuesta por la identificación de múltiples servicios expuestos sin precaución adecuada.

| **Servicios detectados** | | |
|---|---|---|
| ***Puerto*** | ***Servicio*** | ***Riesgo*** |
| 21 | FTP | Acceso no autenticado. |
| 22 | SSH | Acceso privilegiado. |
| 80 | HTTP | Acceso vulnerable. |
| Se identifico la presencia de WordPress y múltiples puntos de acceso. | | |

## 7. Hallazgos de seguridad.

**FTP con acceso anónimo.**

Permite la autenticación anónima lo cual implica que cualquier atacante puede:

- Conectarse sin credenciales.
- Enlistar contenido.
- Descargar y subir archivos.

**Impacto:**

- Ejecución de comandos de forma remota.
- Realización de movimiento lateral.
- Posibilidad de subir archivo malicioso.
- Fuga de información.

***Severidad ALTA.*** 🔴

**Explotación:** Se realizo conexión mediante el comando “ftp 192.168.1.148” resultando en una conexión exitosa y dando acceso al sistema FTP.

**WordPress expuesto.**

Durante el análisis se identifico que el panel de administrador de WordPress /wp-admin es públicamente accesible.

Impacto.

- Posible escalacion de privilegios.
- Compromiso del sitio web.
- Da lugar a la ejecución de código.
- Enumeración de usuario valido.

Severidad ALTA. 🔴

**Explotación:** Enumeración de usuarios mediante herramientas de escaneo para posteriormente dar lugar a un ataque de diccionario.

**XML-RPC habilitado.**

Encontró que /xmlrpc.php es accesible. Esto permite múltiples intentos de login en una sola petición.

***Severidad ALTA.*** 🔴

**Explotación:** Ataque de fuerza bruta masivo.

**Impacto:**

- Compromiso de cuentas.
- Bypass de seguridad.

**Directory listing habilitado.**

Se encontró la ruta /wp-content/uploads/ durante el análisis lo cual muestra una exposición directa de los archivos del servidor.

**Impacto:**

- La recolección de información.
- El descubrimiento de archivos sensibles.

***Severidad MEDIA.*** 🟡

**Explotación:** Acceso vía navegador mostrando archivos del servidor a proteger.

**Exposicion de archivos informativos.**

Se identifico la exposición de “readme.html” junto con información visible del sistema.

**Impacto:**

- Identificación de versión.
- Posibilidad de explotación dirigida.

***Severidad MEDIA.*** 🟡

**Explotación:** Acceso directo al archivo mediante navegador.

**Permisos inseguros en “wp-config.php”.**

Archivo con permisos elevados sin restricción.

**Impacto:**

- Compromiso total del sistema.
- Acceso a credenciales.

***Severidad ALTA.*** 🔴

## 8. Corrección de vulnerabilidades.

**FTP con acceso anónimo.**

El acceso anónimo fue deshabilitado en el servicio FTP y se restringieron los permisos de escritora para evitar accesos no autorizados. Adicionalmente se desactivo o bloqueo el servicio para eliminar este vector de ataque por completo.

**XML-RPC habilitado.**

Mediante configuración en el servidor apache se bloqueo el acceso al archivo xmlrpc.php impidiendo así el uso para ataques de fuerza bruta.

**Directory Listing.**

Se deshabilito el listado de directorios en el servidor web evitando la exposición de archivos y la estructura interna del sistema.

**Permisos inseguros en “wp-config.php”.**

Se corrigen los permisos del archivos wp-config.php limitando el acceso al usuario propietario mediante permisos restrictivos protegiendo asi la informacion critica que se contiene en el mismo.

**Exposición de información.**

Se elimino y restringió el acceso al archivo “readme.html” evitando así la divulgación de información acerca de la versión del sistema.

**WordPress expuesto.**

Se tomaron medidas para limitar la enumeración de usuarios, proteger el acceso al panel administrativo incluyendo el uso de autenticación robusta y restricciones de acceso para evitar futuros ataques de fuerza bruta.

## 9. Conclusión.

El sistema analizado presentaba múltiples vulnerabilidades criticas las cuales comprometían gravemente la seguridad. Tras aplicar las medidas correctivas adecuadas se lograron los siguientes resultados:

- Bloqueo accesos no autorizados.
- Mejora en la configuración de servicios.
- Reducción de la superficie de ataque.

# 10. Anexos.

## Escaneo de puertos y vulnerabilidades

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sv 192.168.1.148
Nmap 7.98 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sL: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
  -p <port ranges>: Only scan specified ports
    Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
  --exclude-ports <port ranges>: Exclude the specified ports from scanning
  -F: Fast mode - Scan fewer ports than the default scan
  -r: Scan ports sequentially - don't randomize
  --top-ports <number>: Scan <number> most common ports
  --port-ratio <ratio>: Scan ports more common than <ratio>
SERVICE/VERSION DETECTION:
  -sV: Probe open ports to determine service/version info
  --version-intensity <level>: Set from 0 (light) to 9 (try all probes)
  --version-light: Limit to most likely probes (intensity 2)
  --version-all: Try every single probe (intensity 9)
  --version-trace: Show detailed version scan activity (for debugging)
SCRIPT SCAN:
  -sC: equivalent to --script=default
  --script=<Lua scripts>: <Lua scripts> is a comma separated list of
           directories, script-files or script-categories
  --script-args=<n1=v1,[n2=v2,...]>: provide arguments to scripts
  --script-args-file=filename: provide NSE script args in a file
  --script-trace: Show all data sent and received
  --script-updatedb: Update the script database.
  --script-help=<Lua scripts>: Show help about scripts.
```

## Escaneo profundo.

```
┌──(kali㉿kali)-[~]
└─$ nmap -A 192.168.1.148
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 13:15 -0400
Nmap scan report for debian.home (192.168.1.148)
Host is up (0.010s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.1.114
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_  256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp open  http    Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 08:00:27:C6:C5:00 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   10.10 ms debian.home (192.168.1.148)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 13.53 seconds
```

## Escaneo con dirb.

```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.1.148

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Mon Mar 16 13:56:51 2026
URL_BASE: http://192.168.1.148/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.1.148/ ----
==> DIRECTORY: http://192.168.1.148/0/
+ http://192.168.1.148/admin (CODE:302|SIZE:0)
+ http://192.168.1.148/dashboard (CODE:302|SIZE:0)
+ http://192.168.1.148/favicon.ico (CODE:302|SIZE:0)
+ http://192.168.1.148/index.html (CODE:200|SIZE:10701)
+ http://192.168.1.148/index.php (CODE:301|SIZE:0)
+ http://192.168.1.148/login (CODE:302|SIZE:0)
+ http://192.168.1.148/robots.txt (CODE:200|SIZE:109)
+ http://192.168.1.148/server-status (CODE:403|SIZE:278)
==> DIRECTORY: http://192.168.1.148/wp-admin/
==> DIRECTORY: http://192.168.1.148/wp-content/
==> DIRECTORY: http://192.168.1.148/wp-includes/
+ http://192.168.1.148/xmlrpc.php (CODE:405|SIZE:42)

---- Entering directory: http://192.168.1.148/0/ ----
+ http://192.168.1.148/0/index.php (CODE:301|SIZE:0)

---- Entering directory: http://192.168.1.148/wp-admin/ ----
+ http://192.168.1.148/wp-admin/admin.php (CODE:302|SIZE:0)
==> DIRECTORY: http://192.168.1.148/wp-admin/css/
==> DIRECTORY: http://192.168.1.148/wp-admin/images/
==> DIRECTORY: http://192.168.1.148/wp-admin/includes/
+ http://192.168.1.148/wp-admin/index.php (CODE:302|SIZE:0)
==> DIRECTORY: http://192.168.1.148/wp-admin/js/
==> DIRECTORY: http://192.168.1.148/wp-admin/maint/
==> DIRECTORY: http://192.168.1.148/wp-admin/network/
==> DIRECTORY: http://192.168.1.148/wp-admin/user/

---- Entering directory: http://192.168.1.148/wp-content/ ----
+ http://192.168.1.148/wp-content/index.php (CODE:200|SIZE:0)
==> DIRECTORY: http://192.168.1.148/wp-content/plugins/
==> DIRECTORY: http://192.168.1.148/wp-content/themes/
==> DIRECTORY: http://192.168.1.148/wp-content/upgrade/
==> DIRECTORY: http://192.168.1.148/wp-content/uploads/

---- Entering directory: http://192.168.1.148/wp-includes/ ----
```

## Escaneo de usuarios con wpscan e identificación de wordpress.

```
[+] wordpress-user
 | Found By: Wp Json Api (Aggressive Detection)
 |  - http://192.168.1.148/wp-json/wp/v2/users/?per_page=100&page=1
 | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/registe
r

[+] Finished: Mon Mar 16 16:04:55 2026
[+] Requests Done: 82
[+] Cached Requests: 10
[+] Data Sent: 18.695 KB
[+] Data Received: 23.77 MB
[+] Memory used: 207.113 MB
[+] Elapsed time: 00:00:05
```

**FTP ACCESO ANONIMO.**

```
debian@debian:~$ cat /etc/vsftpd.conf | grep anonymous
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
```

**SSH SEGURO.**

```
debian@debian:~$ grep PermitRootLogin /etc/ssh/sshd_config
PermitRootLogin no
```

```
debian@debian:~$ grep PasswordAuthentication /etc/ssh/sshd_config
PasswordAuthentication no
# PasswordAuthentication.  Depending on your PAM configuration,
```

**PUERTOS ABIERTOS NECESARIOS Y CORREGIDOS.**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS 192.168.1.148
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-21 08:54 -0400
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 12.47% done; ETC: 08:56 (0:01:03 remaining)
Stats: 0:00:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 18.43% done; ETC: 08:55 (0:00:53 remaining)
Stats: 0:01:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 94.93% done; ETC: 08:55 (0:00:03 remaining)
Stats: 0:01:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.60% done; ETC: 08:55 (0:00:00 remaining)
Nmap scan report for 192.168.1.148
Host is up (0.22s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:C6:C5:00 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 70.35 seconds
```

**WP-CONFIG.PHP**

**MALA CONFIGURACION**

```
debian@debian:~$ ls -l /var/www/html/wp-config.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30  2024 /var/www/html/wp-config.php
```

## BIEN CONFIGURADO

```
debian@debian:~$ sudo chmod 600 /var/www/html/wp-config.php
debian@debian:~$ ls -l /var/www/html/wp-config.php
-rw------- 1 www-data www-data 3017 Sep 30  2024 /var/www/html/wp-config.php
```

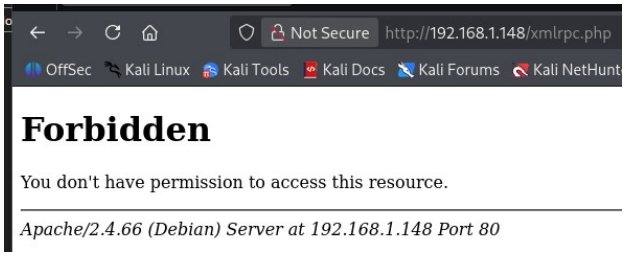
## CORRECCIÓN DE DIRECTORY LISTING

```
debian@debian:~$ grep -R "Options -Indexes" /etc/apache2/
/etc/apache2/apache2.conf:      Options -Indexes +FollowSymLinks
```

## XLMRPC.PHP BLOQUEADO

```
debian@debian:~$ cat /etc/apache2/conf-enabled/block-xmlrpc.conf
<Files "xmlrpc.php">
    Require all denied
</Files>
```

## EVIDENCIA




## FIREWALL

```
debian@debian:~$ sudo ufw status
Status: active

To                         Action      From
--                         ------      ----
22                         ALLOW       Anywhere
80                         ALLOW       Anywhere
22 (v6)                    ALLOW       Anywhere (v6)
80 (v6)                    ALLOW       Anywhere (v6)

debian@debian:~$
```

## EXPLOTACIÓN DE FTP

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 21 -sV 192.168.1.148
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-21 09:25 -0400
Nmap scan report for 192.168.1.148
Host is up (0.021s latency).

PORT   STATE    SERVICE VERSION
21/tcp filtered ftp
MAC Address: 08:00:27:C6:C5:00 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.1.148
Connected to 192.168.1.148.
220 (vsFTPd 3.0.3)
Name (192.168.1.148:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

## EXPLOTACIÓN DE XML-RPC

```
┌──(kali㉿kali)-[~]
└─$ wpscan --url http://192.168.1.148 --usernames wordpress-user \ --passwords /usr/share/wordlists/rockyou.txt \ --passw
ord-attack xmlrpc
```

```
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
 Checking Config Backups - Time: 00:00:03 <==========================================> (137 / 137) 100.00% Time: 00:00:03

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sat Mar 21 09:37:00 2026
[+] Requests Done: 183
[+] Cached Requests: 6
[+] Data Sent: 46.608 KB
[+] Data Received: 669.578 KB
[+] Memory used: 268.727 MB
[+] Elapsed time: 00:00:15
```

## CORRECCIÓN.

```
debian@debian:~$ curl http://192.168.1.148/xmlrpc.php
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.66 (Debian) Server at 192.168.1.148 Port 80</address>
</body></html>
```